



中国互联网安全大会



360互联网安全中心

ISC
2015

数据驱动安全

2015 中国互联网安全大会
China Internet Security Conference

从微观到宏观
大数据如何改变安全

WHY BIG DATA

我们面对的是什么

2015 - Kaspersky (Duqu 2.0)

2015 - Hacking Team

2014 – SONY

2014 - APPLE

2014 - JP MORGAN CHASE

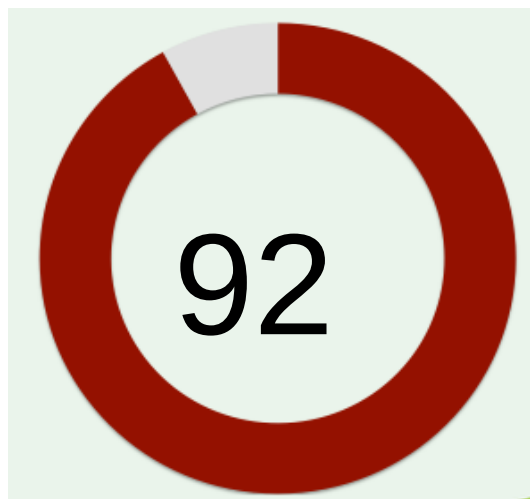
2014 - Target

- 2014年79790家公司被黑泄漏数据；
- 2122家公司公开确认信息被窃取；
- 500强企业超过半数；
- 60% 的案例里，攻击者仅需要几分钟就可以的手；
- 70%-90%的样本都是有针对性的；
- 75%的攻击会在24小时内从一个受害者快速扩展到其他受害者。

-- 《2015 DBIR》

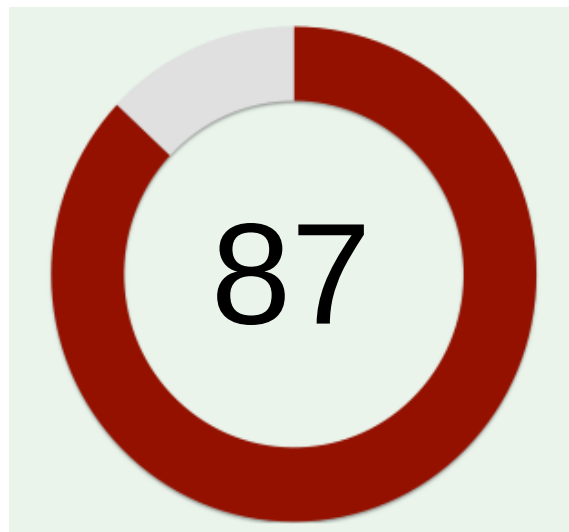


特征码技术很难有效检测当前威胁



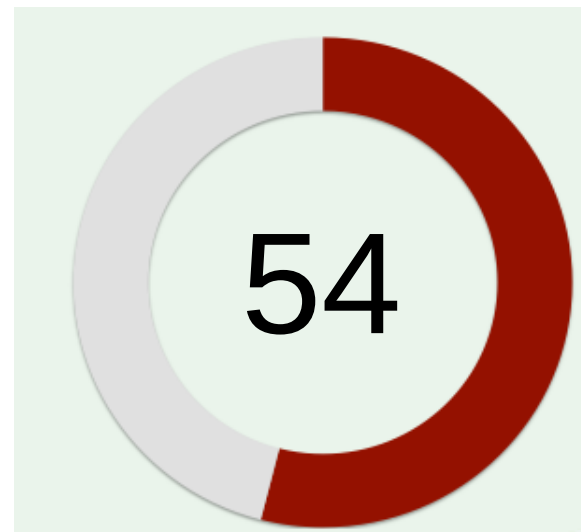
成功的攻击中，
92%是由于外部
攻击者

《DBIR2013》



攻击大多不能通
过现有安全设备
发现，87%源自
外部的报告

《DBIR2013》

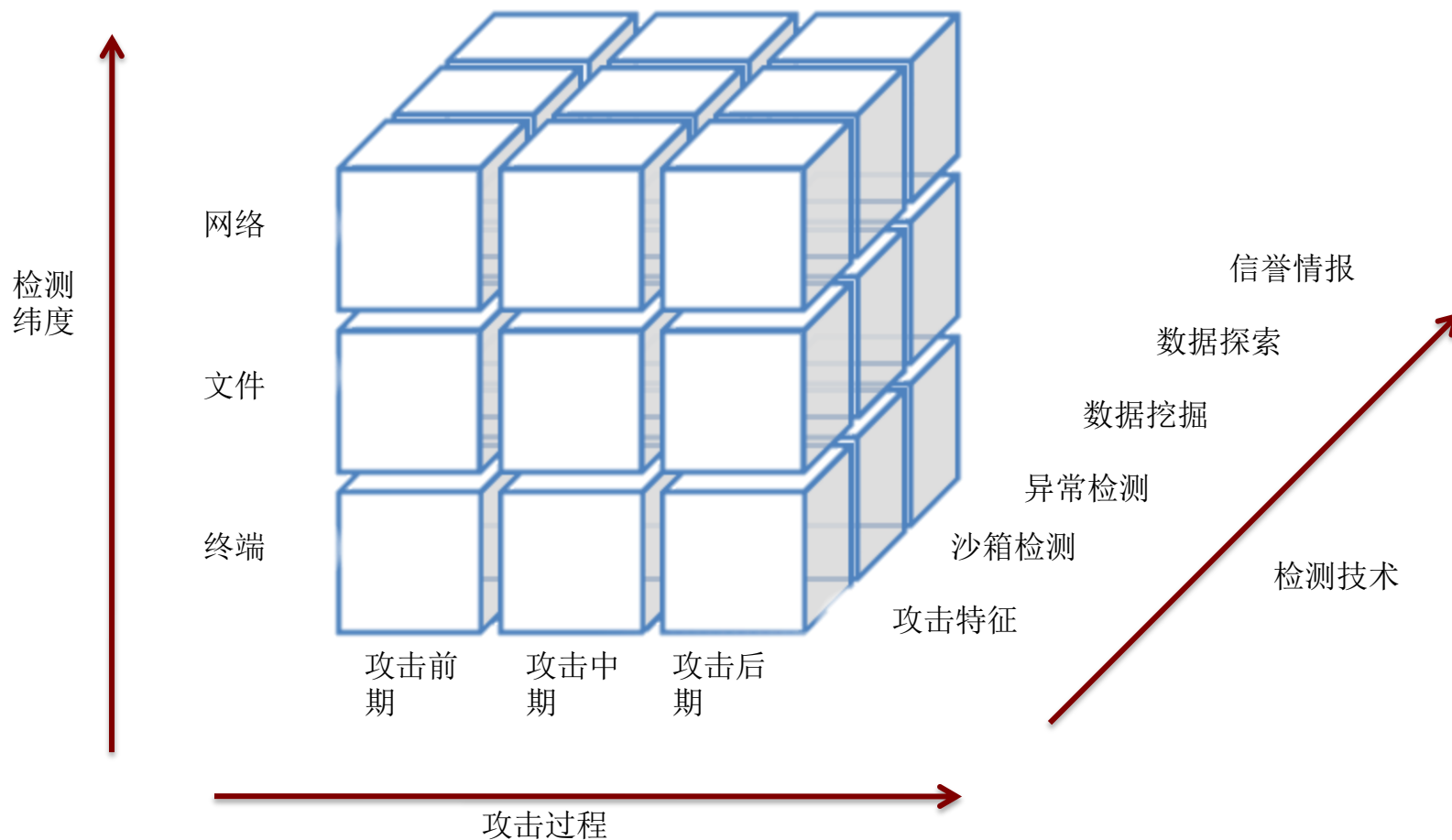


互联网上的传播
的病毒，54%不
能通过AV检测

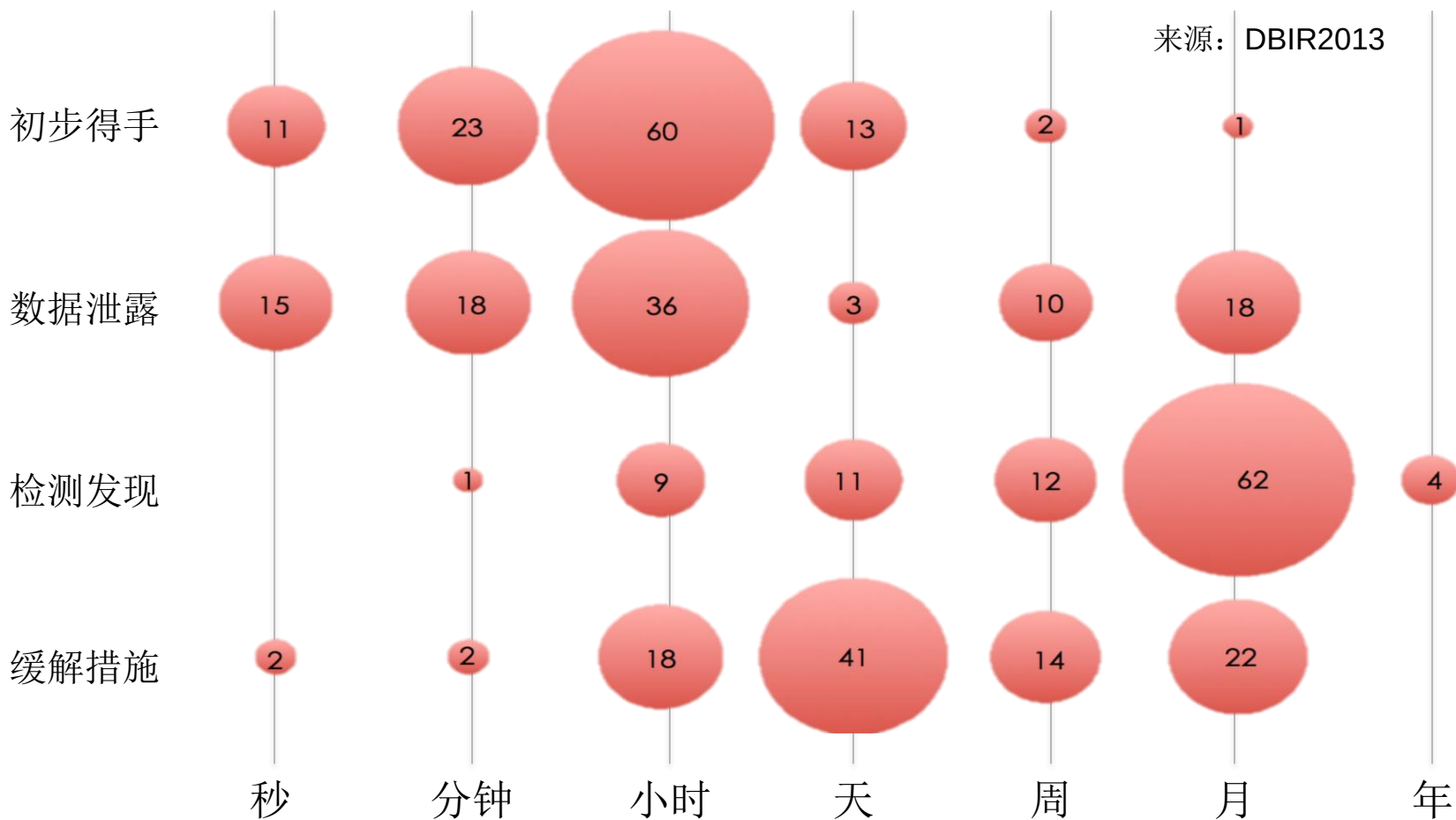
NTT Group

以边界安全为主构建的体系已经失效

- 面对当今主流的定向攻击，任何单一化的检测均不能达到理想的检测效果，立体检测是必然选择。



回归更高级威胁的本质

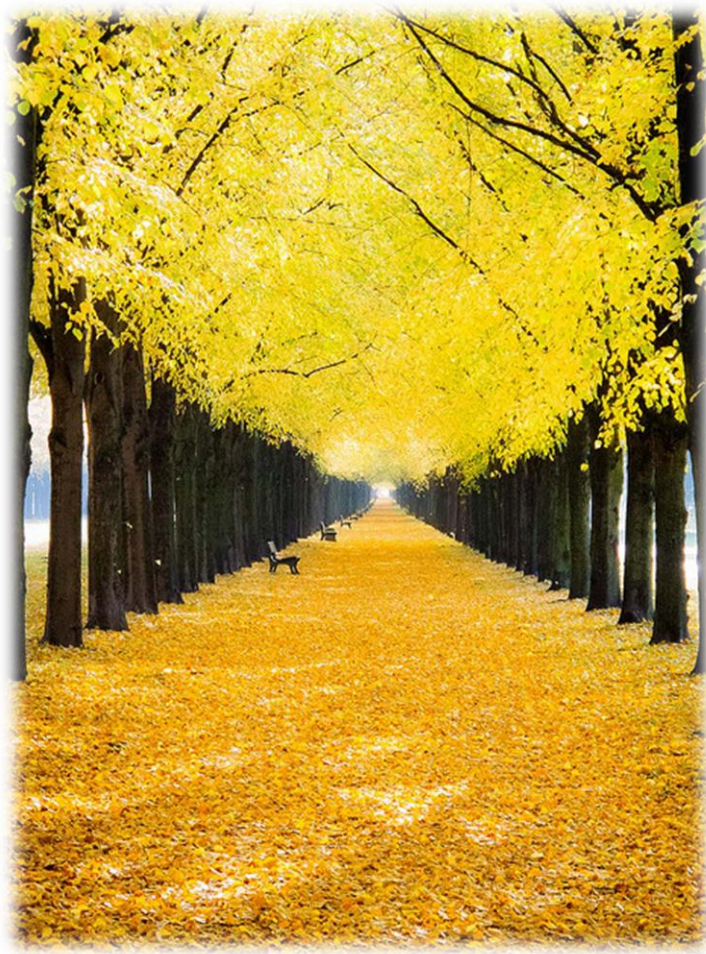


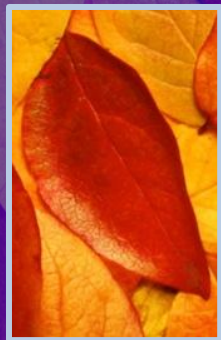
传统安全设备从本地网络
或终端数据中发现未知威胁，
对于互联网而言，仿佛研究森林中的一片叶子。



叶子 (1:本地数据) 与森林 (N:互联网数据) 的关系

- 时间 (Time(N) 早于 Time(1))
 - 今天特定客户的未知威胁往往昨天就在互联网上存在
- 关联 ($1+N \gg 1$)
 - 将本地数据与互联网海量多维信息进行关联分析，效果会远远超过单单研究1
- 普适 ($N=1+1+1+\dots+1$)
 - 针对互联网海量多维信息，采用机器学习挖掘所得到的检测模型，可有效适用于1





在大数据时代，一片叶子
上的威胁发现，必须借助
针对整个森林的威胁研究

空间换时间

通过对互联网海量多维数据的分析、挖掘和关联，才能真正解决在本地数据中快速发现未知威胁的难题

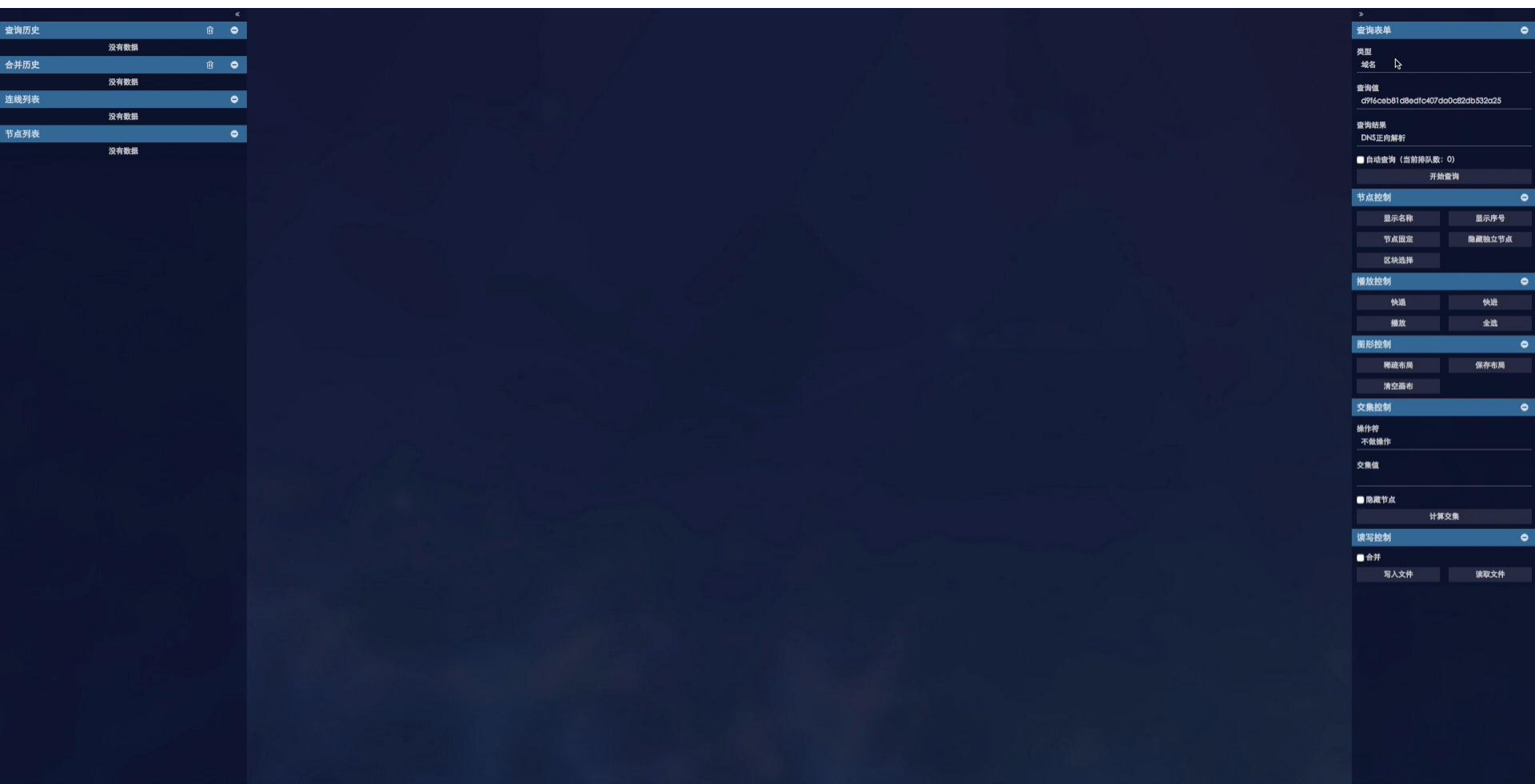
理想是否太骨感：一个大数据安全分析的例子



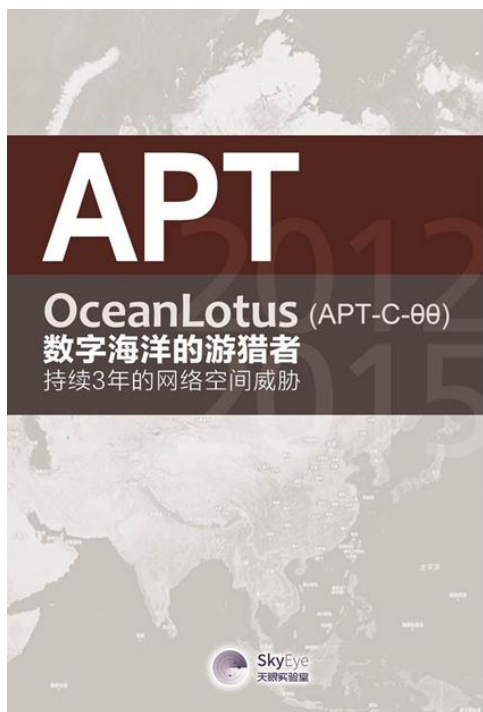
中国互联网安全大会



360互联网安全中心



另一个案例：H组织



<https://skyeve.360safe.com>

据360天眼实验室发现，2012年4月起，与我国有领土争端的某国家对**中国政府、科研院所、海事机构、海运建设、航运企业**等相关重要领域展开了有计划、有针对性的长期渗透和攻击，我们称之为“H组织”。

该组织主要通过**鱼叉攻击和水坑攻击**等方法，配合多种社会工程学手段进行渗透，向境内特定目标人群传播**特种木马**程序，秘密控制部分政府人员、外包商和行业专家的电脑系统，窃取系统中相关领域的**机密资料**。



更多的案例：独立发现的APT组织



中国互联网安全大会



360互联网安全中心

APT活动	境内感染量	首次发现时间	最近发现时间	影响省份数	影响行业	感染方式
APT-C-00	1047	2012/4	2015/5/22	29	政府、海洋、海事	鱼叉邮件、水坑
APT-C-01	235	2012/2/15	2015/4/5	28	政府	鱼叉邮件
APT-C-02	17	2014/4/3	2014/6/29	3	科研、教育	鱼叉邮件
APT-C-03	180	2014/8/1	2015/4/14	9	教育	鱼叉邮件
APT-C-04	5	2014/11/3	2014/12/15	2	非政府组织	鱼叉邮件
APT-C-05	12	2015/2/12	2015/3/24	3	政府	鱼叉邮件
APT-C-06	4	2015/2/24	2015/3/7	3	科研	鱼叉邮件

INSIDE BIG DATA ANALYTICS FOR SECURITY

关键能力之一：真正拥有数据

海量情报数据

存储计算能力

数据挖掘技术

可视化分析技术

全球独有的样本库

- 总样本**95亿**
- 每天新增**900万**

主防库

- 覆盖**5亿**客户端
- 总日志数**50000亿**条
- 每天新增**100亿**

最大中文漏洞库

- 总漏洞数超过**40万**
- 每天新增可达**500个**

互联网域名信息库

- **50亿**DNS解析记录
- 每天新增**100万**

最大的存活网址库

- 每天查询**300亿**条
- 每天处理**100亿**条

海量情报数据

存储计算能力

数据挖掘技术

可视化分析技术

互联网大数据技术路线

利用最廉价PC服务器+开源/自主开发软件构建而成

数据的可靠性，扩展性全部自主可控，成本不到IOE方案的1/100

存储计算能力的关键在于规模

大数据服务器规模超过40000台

总存储数据量接近1EB，每天新增超过1PB

每天各种数据计算任务10万个，每天处理数据量10PB

具备一分钟内调动几十万颗CPU核参与计算能力

具备一秒钟处理1TB数据的能力

- 成本
 - 采用廉价PC服务器+开源软件，避免采用磁盘阵列等昂贵设备
- 可靠
 - 采用分布式并行架构，可以达到互联网级别的可靠性，优于商业方案
- 效率
 - 将计算推送到存储设备上进行，避免采用传统架构，如磁阵等，否则一定会遭遇I/O或网络传输等瓶颈
- 适配
 - 必须合理采用存储和计算架构，不同应用会对存储和计算带来不同的要求，避免将Hadoop作为大数据的代名词。
- 规模
 - 规模决定了大数据方案的最终交付质量，如果缺乏运营大数据的经验，则大数据方案的交付成本会非常高昂，常常导致失败。

海量情报数据

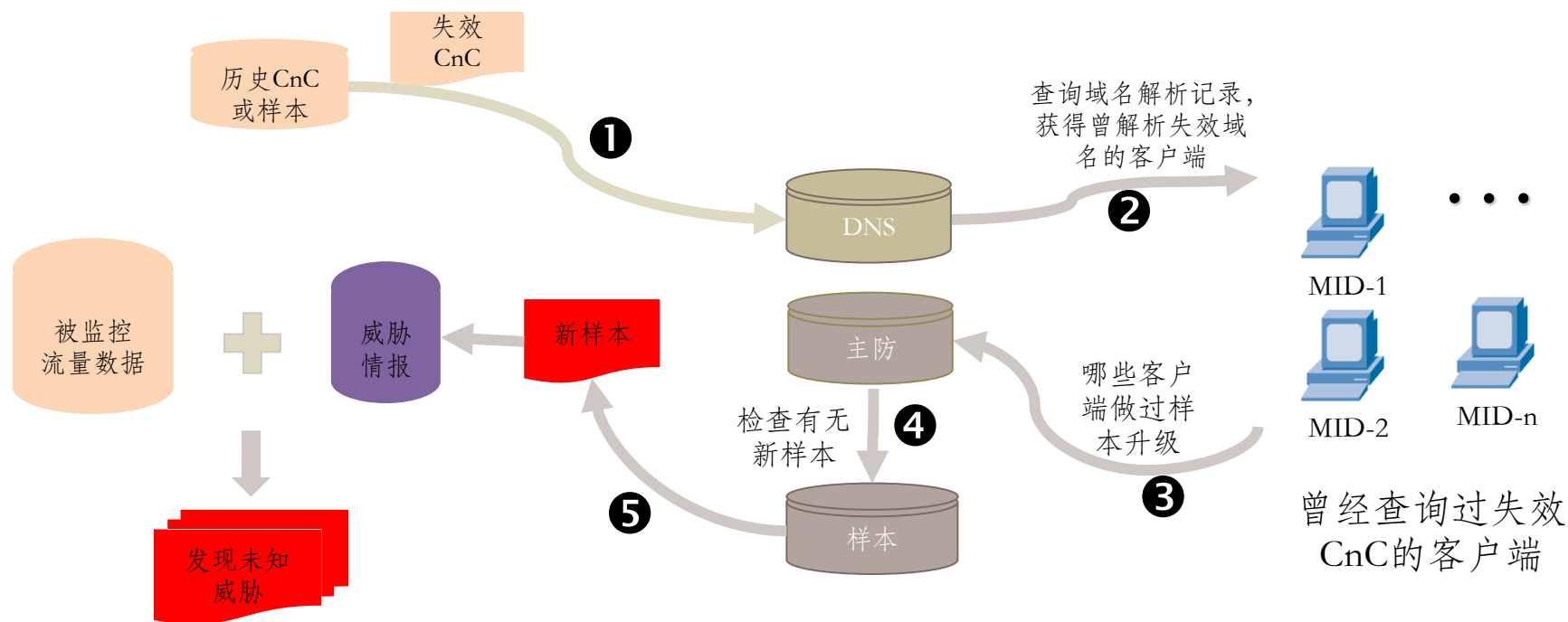
存储计算能力

数据挖掘技术

可视化分析技术

- 以未知恶意软件发现引擎为例
 - 基于海量**数据挖掘**、引入**机器学习**算法，能够有效准确识别未知恶意软件，是人工智能技术在恶意程序自动分析领域中的首次商业应用
 - 样本聚类分析，相似样本发现，同源样本追踪

例：数据关联方法寻找新型样本



方法：通过失效域名的解析记录，关联寻找到感染者，部分客户端有可能进行过样本升级，再通过主防日志获得新型的恶意样本。

例：采用深度学习识别未知流量

- 深度学习的应用

搭建了高性能GPU并行计算平台，专门用于深度学习，如未知协议识别、同源性域名发现等

09:00

ATTACKING YOUR TRUSTED
CORE: EXPLOITING TRUSTZONE
ON ANDROID

Di Shen
Mandalay Bay EF
09:00 - 09:25

CRACKLORD: MAXIMIZING
PASSWORD CRACKING BOXES

Lucas Morris & Michael McAtee
Lagoon K
09:00 - 09:25

EXPLOITING XXE
VULNERABILITIES IN FILE
PARSING FUNCTIONALITY

Willis Vandevanter
South Seas GH
09:00 - 09:25

MY BRO THE ELK: OBTAINING
CONTEXT FROM SECURITY
EVENTS

Travis Smith
South Seas CDF
09:00 - 09:25

REMOTE PHYSICAL DAMAGE
101 - BREAD AND BUTTER
ATTACKS

Jason Larsen
Mandalay Bay BCD
09:00 - 09:25

ROPINJECTOR: USING RETURN
ORIENTED PROGRAMMING FOR
POLYMORPHISM AND ANTIVIRUS
EVASION

Giorgos Poullos &
Christoforos Ntantogian &
Christos Xenakis
South Seas ABE
09:00 - 09:25

TAXONOMIC MODELING OF
SECURITY THREATS IN
SOFTWARE DEFINED
NETWORKING

Jennia Hizver
South Seas JJ
09:00 - 09:25

THE APPLICATIONS OF DEEP
LEARNING ON TRAFFIC
IDENTIFICATION

Zhanyi Wang & Chuanming Huang &
Zhuo Zhang & Bo Liu
Jasmine Ballroom
09:00 - 09:25

关键能力之四：数据可视化

海量情报数据

存储计算能力

数据挖掘技术

可视化分析技术

- 基于多维数据的关联，通过多种图形展现方式，构造能够帮助安全专家，对未知威胁进行分析，展现出数据之间的内在关联关系

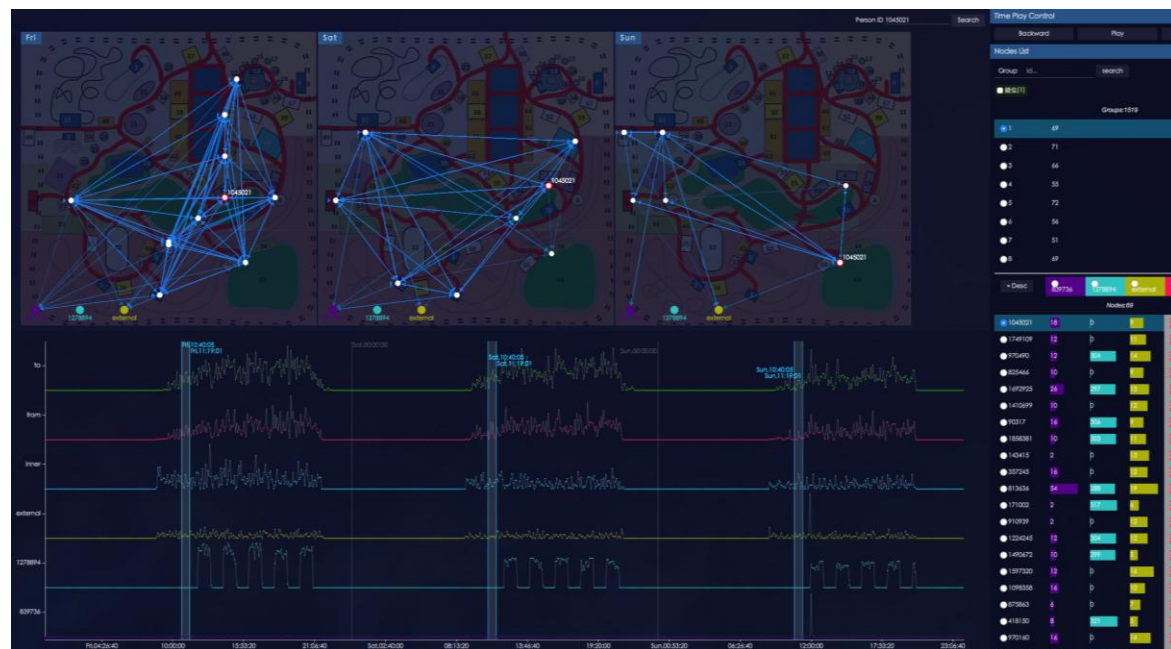


2015

数据可视分析挑战赛 ChinaVis Data Challenge

第二届中国可视化与可视分析大会

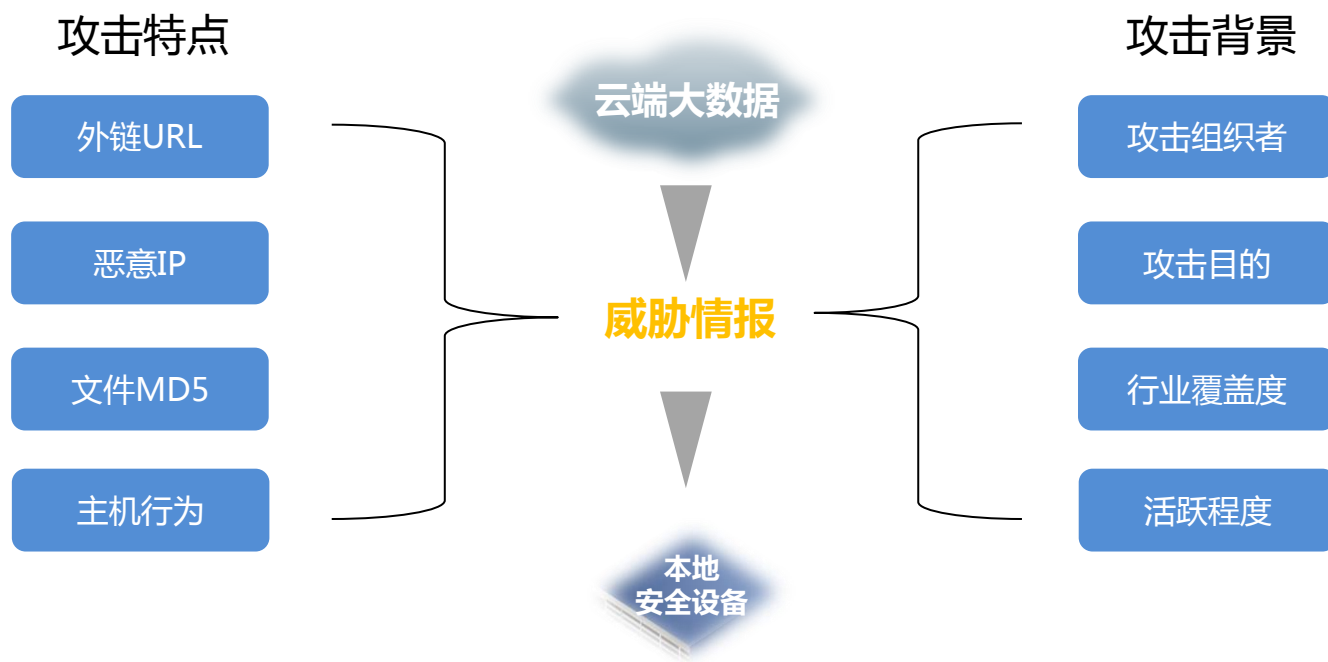
北大可视化联合实验室



CHANGES IN SECURITY WITH BIG DATA

Change1：威胁情报增强了“见广”能力

威胁情报（Threat Intelligence）是一种基于证据的描述威胁的一组关联的信息，包括威胁相关的环境信息、采用的手法机制、指标、影响，以及行动建议等。与传统的单点的病毒或信誉等信息不同，这一系列对于攻击威胁的信息，可以让我们了解高级威胁的全貌，并被抽象成可机读威胁情报（MRTI），用来进行应对决策，并对威胁进行响应。



见广

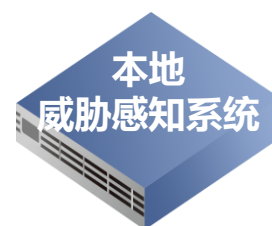


大数据+分析挖掘可
有效、快速的发现未
知威胁，如免杀木马



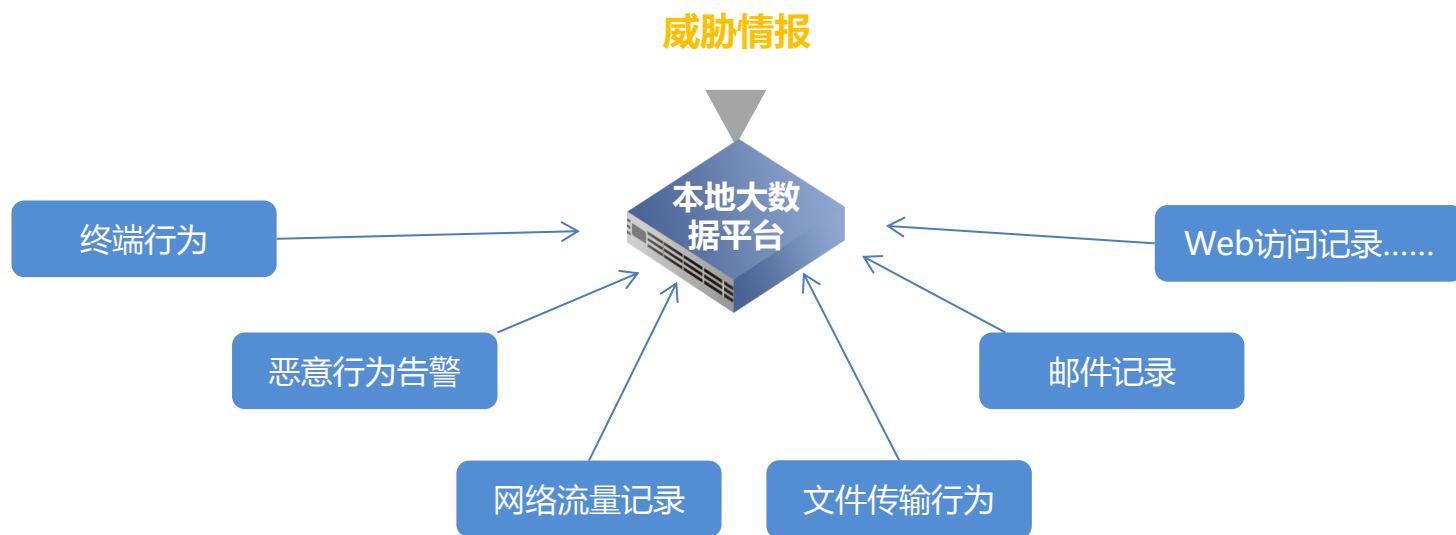
给出高级攻击的相关
信息与行动指示器，
以可机读威胁情报
(MRTI) 形式推送
给本地部署的设备

见微



企业本地部署设备或软件
对各层数据进行采集、还
原、存储并索引各类数
据，用于发现与溯源

Change2：本地大数据提升了“见微”



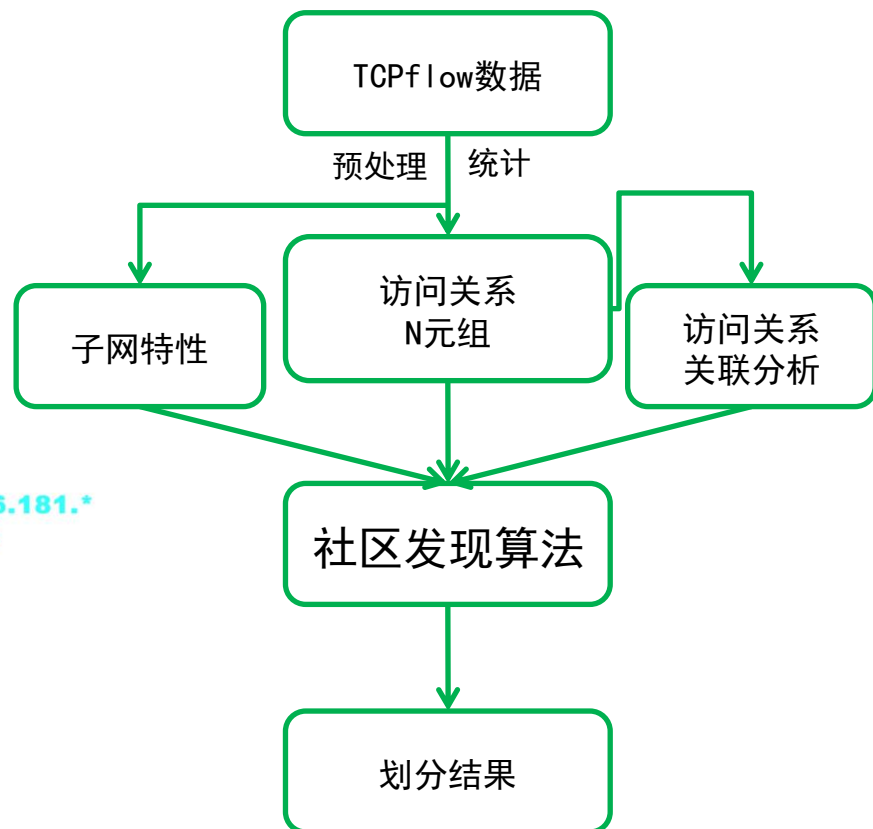
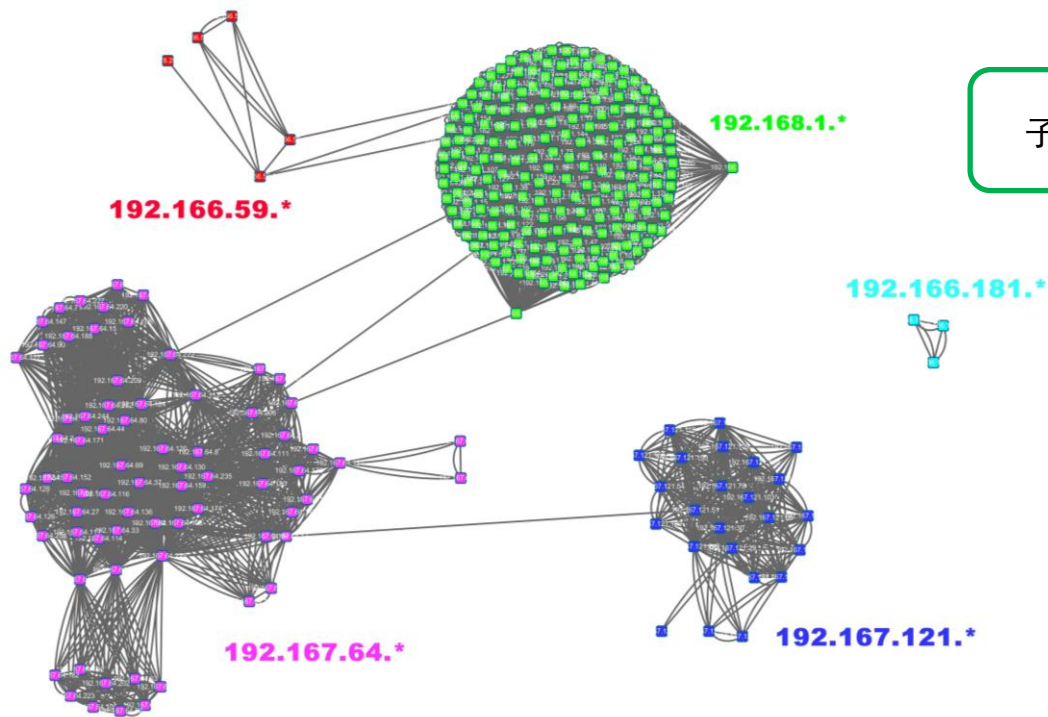
- 用户侧形成轻量级大数据平台
 - 采集设备轻量化，可以具备更高性能及稳定性
 - 整体流量的还原、终端行为以及其他海量日志存储与计算能力 – 尽量还原，记录下来才能发现
 - **千亿+日志条目的秒级快速检索；**
 - 针对本地数据细粒度的挖掘，以降低分析人员的工作量，提升效率

- 深度学习
 - 协议识别/应用程序识别
 - 恶意样本识别
 - 黑白域名判别
- 图挖掘
 - 资产识别与划分
 - 线索与关联
- 数据分析
 - 周期性分析
 - 关联分析

“见微”的能力：内网资产划分

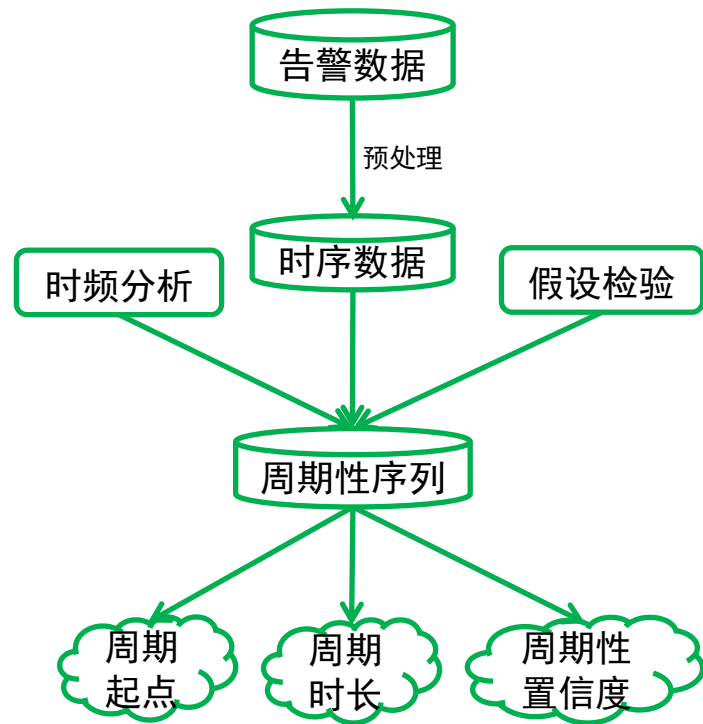
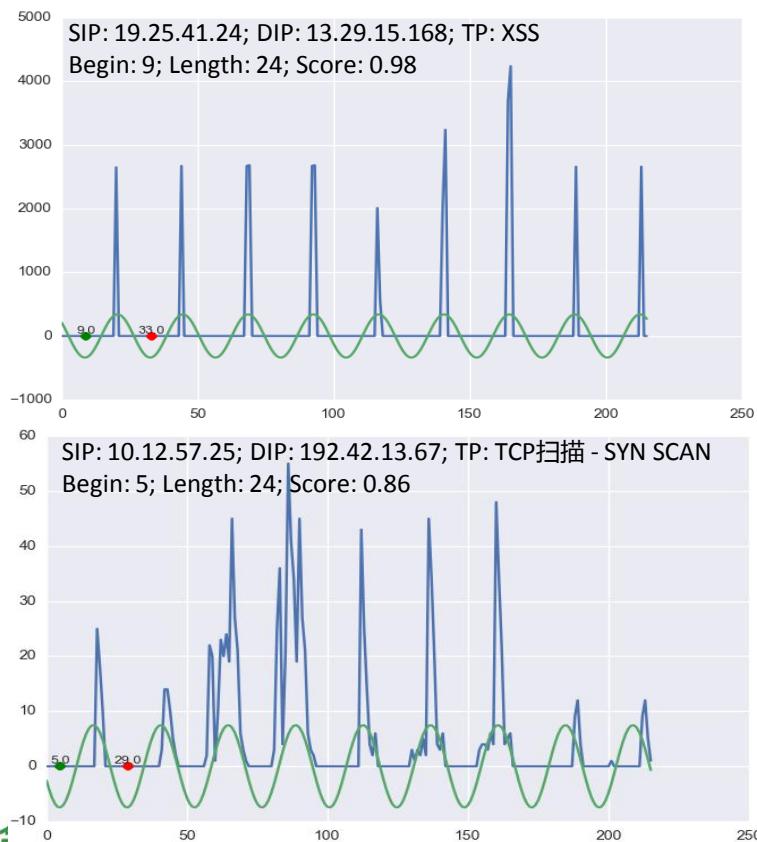
资产划分

基于社区划分算法

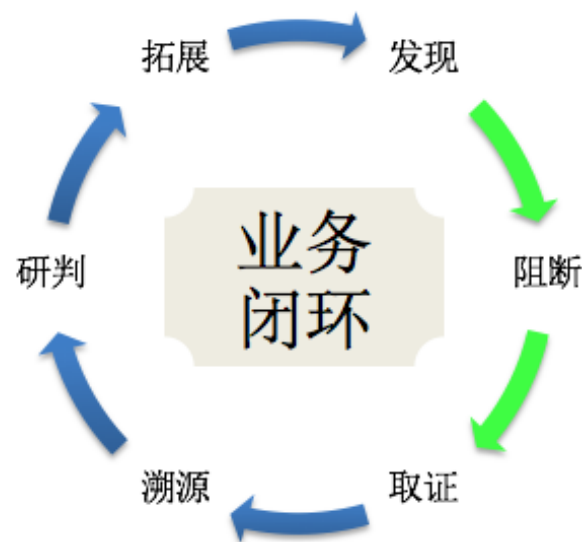


告警数据挖掘

攻击行为的周期性分析



- 发现
 - 入侵检测
 - 受控检测
 - 破坏检测
- 阻断
 - 网络阻断
 - 查杀处置
- 取证
 - 痕迹取证
 - 危害取证
- 回溯
 - 攻击回溯
 - 样本回溯
- 研判
 - 身份标示
 - 空间定位
 - 动机判断
- 拓展
 - 时间拓展
 - 空间拓展



- 威胁情报基础数据快速搜索
 - 安全分析人员可通过搜索引擎，针对IP、域名、文件等多个对象进行查询，获得相关对象的“身份证”信息
 - 针对特定对象启用更加精细的鉴定手段，如云端沙箱、人肉引擎等
- 多维可视化关联分析系统
 - 针对IP、域名、文件多个对象进行可视化关联分析，寻找潜在新兴威胁
 - 可将分析人员进行切分，在不同安全分析人员进行协同以及结果共享

- 安全专家
 - 漏洞挖掘及利用
 - 恶意样本分析
 - 网络规划及协议分析
 - 软硬件驱动
 - 主机安全/手机安全/服务器安全
 - 无线安全/智能硬件安全
 - 工控安全
- 数据专家
 - 存储&计算
 - 数据挖掘
 - 机器学习
- 业务专家
 - 精通各细分行业安全业务的专家

传统的 商业模式	模式1 产品销售	模式2 服务驻场	模式3 定制开发
模式概述	通过软硬件销售实现一次性变现	通过销售服务人员实现一次性变现	通过外包开发人员实现一次性变现
模式优点	可大规模复制	客户粘度高，可带动产品销售	客户粘度高，可带动产品销售
模式缺点	无持续性，客户粘度低	无法开展大规模复制且无持续性	无法开展大规模复制且无持续性
应用场景	所有网关或终端产品	咨询、评估、渗透、运维	SOC、4A
市场现状	主流	主流	主流

- 传统商业模式的最大特点：堆人
 - 人员规模快速增长，运营成本居高不下
 - 安全价值在服务，传统模式高昂的成本导致无法有效满足客户需求
- 传统模式造成厂商与客户：割裂
 - 产品研发模式缺乏互联网思维，更新慢
 - 缺乏数据，造成核心技术竞争力落后
 - 很难实现及时的安全应急响应

新兴的商业模式	模式4 数据模式	模式5 云端服务
概述	对核心数据使用收费， 持续性收费	云端针对多客户服务运营，持续性收费
模式优点	可大规模复制，具有持续性，且客户粘度高	可大规模复制，且具有持续性
模式缺点	建设成本高，且客户接受度需教育	建设成本高，且客户信任度问题
应用场景	威胁情报inside、数据驱动的安全分析工具	Cloud Anti-DDoS、 Cloud Security Analysis
市场现状	较少	较少

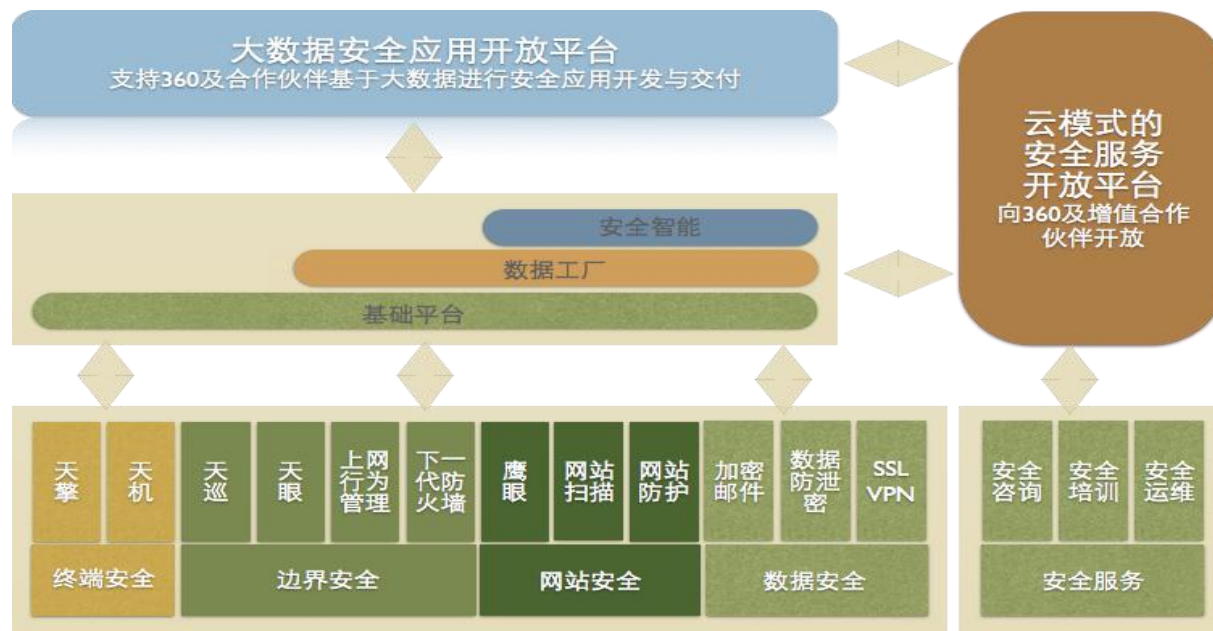
大数据提供了全新的开放平台模式

借助大数据及云计算，构建开放平台，改造模式2/模式3

- 安全应用开放平台
- 安全服务开放平台

开放平台的价值

- 解决模式2和模式3的缺点，增加客户粘度
- 改变上下游价值关系，重建生态系统



BUT.....

Big Data is NOT a Silver Bullet for Security

- 反威胁情报技术
- 噪声
- 线头与线尾
- 人





中国互联网安全大会



360互联网安全中心

数据驱动安全